



System Work Needed - Priority Breakdown

Last Updated: December 18, 2025

Overall Production Readiness: 82%

🚨 CRITICAL - Must Fix Before Launch

1. Security Hardening (96 hours)

Status: ⚠️ 75/100 - Critical gaps identified

CORS Headers (40 hours)

- **Problem:** 116/154 edge functions use wildcard `'Access-Control-Allow-Origin': '*'`
- **Risk:** Any website can call your APIs
- **Fix:** Replace with specific origins

```
// Current (INSECURE):  
'Access-Control-Allow-Origin': '*'  
  
// Should be:  
'Access-Control-Allow-Origin': 'https://cravenusa.com'
```

- **Priority: P0 - Immediate**

XSS Vulnerabilities (16 hours)

- **Problem:** 11 files use `innerHTML` or `dangerouslySetInnerHTML` without sanitization
- **Risk:** Malicious scripts can be injected
- **Fix:** Implement DOMPurify for all HTML rendering
- **Priority: P0 - Immediate**

Rate Limiting (24 hours)

- **Problem:** No rate limiting on critical endpoints
- **Affected Endpoints:**
 - Phone verification
 - Login/auth
 - Payment processing
 - Order creation
- **Risk:** Brute force attacks, API abuse, cost spikes
- **Fix:** Add exponential backoff and rate limits
- **Priority: P0 - Immediate**

RLS Policy Review (16 hours)

- **Problem:** 9 tables have overly permissive Row Level Security policies
 - **Risk:** Data leaks, unauthorized access
 - **Fix:** Audit and tighten policies
 - **Priority: P0 - This Week**
-

2. Testing Coverage (168 hours)

Status: ⚠️ **2% coverage** - Target: 80%

- **Current:** 2 test files, 1 E2E test
 - **Needed:**
 - Unit tests for auth flows
 - Unit tests for payment processing
 - Unit tests for order management
 - Integration tests for critical paths
 - E2E tests for complete user journeys
 - **Priority: P1 - Week 3-6**
-

🚫 HIGH PRIORITY - Launch Blockers

3. iOS App Store Submission (40+ hours)

Status: ✖️ **Not submitted**

- Android: ☒ Built and working
 - iOS: ✖️ Needs:
 - Apple Developer certificates
 - App Store screenshots (all sizes)
 - App Store metadata
 - Submit for review (2-7 days)
 - **Priority: P1 - Week 5-6**
-

4. Payment Processing Verification (8 hours)

Status: ☒ **Code complete** - Needs verification

Note: Moov.io has been **completely removed**. System is now **Stripe-only**.

Stripe Configuration:

- ☒ Edge functions use **STRIPE_SECRET_KEY** from environment
- ☒ No hardcoded test keys in functions
- ⚠️ Verify **STRIPE_SECRET_KEY** is set in Supabase secrets
- ⚠️ Verify **VITE_STRIPE_PUBLISHABLE_KEY** in frontend **.env**
- ⚠️ Test end-to-end payment flow

Action Items:

1. Verify Stripe keys are configured (not test keys)
2. Test customer checkout flow
3. Test driver payouts
4. Test restaurant payouts
5. Verify webhooks are receiving events

Priority: P0 - Before Launch

🕒 MEDIUM PRIORITY - Important but Not Blocking

5. Intern Program Database (13 hours)

Status: ✖ 100% mock data

Affected Components:

- `InternConversion.tsx` - Hardcoded requirements, offers, stages
- `InternWork.tsx` - Hardcoded tasks, deliverables, logs
- `InternAcademicCredit.tsx` - Hardcoded credit records
- `InternExit.tsx` - Hardcoded offboarding steps
- `InternPerformance.tsx` - Hardcoded KPIs, reviews, skills

Fix Required:

1. Create database tables (3 hours)
2. Replace mock data with queries (8 hours)
3. Test CRUD operations (2 hours)

Note: Can launch without this - hide intern routes or show "Coming Soon"

Priority: P2 - Can wait

6. HR Dashboard Mock Data (2 hours)

Status: ⚠ Partial mock data

- HR Portal: Mock monthly charts
 - CFO Portal: Hardcoded DPO calculation
 - **Fix:** Query real employee data and calculate metrics
 - **Priority: P2 - Low effort, can do anytime**
-

7. Performance Optimization (112 hours)

Status: ⚠ Not measured

Needed:

- Lighthouse audit and fixes (24 hours)
- Code splitting implementation (16 hours)

- Service worker caching (16 hours)
- Database query optimization (24 hours)
- CDN setup (8 hours)
- Load testing (24 hours)

Current Issues:

- Bundle size: ~5MB (target: <2MB)
- No performance metrics collected
- No load testing completed

Priority: P2 - Before full production, not soft launch

🌀 LOW PRIORITY - Nice to Have

8. Feature Enhancements

- Customer review system UI (24 hours)
- Advanced analytics dashboards (40 hours)
- Fraud detection (40 hours)
- A/B testing framework (24 hours)
- Enhanced reporting (40 hours)

Priority: P3 - Post-launch

📊 Summary Table

Category	Issue	Hours	Priority	Blocker?
Security	CORS hardening	40	P0	☑ YES
Security	XSS fixes	16	P0	☑ YES
Security	Rate limiting	24	P0	☑ YES
Security	RLS review	16	P0	☑ YES
Testing	Test suite	168	P1	⚠ Recommended
Mobile	iOS submission	40+	P1	⚠ Recommended
Payment	Stripe verification	8	P0	☑ YES
Data	Intern DB	13	P2	✗ No
Data	HR real data	2	P2	✗ No
Performance	Optimization	112	P2	✗ No

🚀 Recommended Launch Plan

Phase 1: Critical Security (Weeks 1-2) - 104 hours

☑ MUST DO:

1. Fix CORS headers (all 154 functions)
2. Fix XSS vulnerabilities (11 files)
3. Add rate limiting
4. Review RLS policies
5. Verify Stripe configuration
6. Test payment flows

Phase 2: Soft Launch (Week 3)**After Phase 1 complete:**

- ☒ Launch customer ordering (web)
- ☒ Launch driver app (Android)
- ☒ Launch restaurant portal
- ☒ Launch admin portal
- ☒ Hide intern program (or show "Coming Soon")
- ☒ Show "Coming Soon" for HR analytics

Phase 3: Mobile Complete (Week 5-6) - 40+ hours

- Submit iOS app
- Complete App Store process

Phase 4: Full Production (Week 7-10) - 280 hours

- Complete test suite
- Performance optimization
- Load testing
- Intern program implementation

🎯 Immediate Next Steps (This Week)**1. Day 1-2: Verify Stripe Configuration**

- ☐ Check Supabase secrets for `STRIPE_SECRET_KEY`
- ☐ Check frontend `.env` for `VITE_STRIPE_PUBLISHABLE_KEY`
- ☐ Test a real payment end-to-end
- ☐ Test driver payout
- ☐ Test restaurant payout

2. Day 3-5: Security - Phase 1

- ☐ Fix CORS in top 20 most-used functions
- ☐ Fix top 5 XSS vulnerabilities
- ☐ Add rate limiting to auth endpoints
- ☐ Add rate limiting to payment endpoints

3. Week 2: Security - Phase 2

- ☐ Complete all CORS fixes
 - ☐ Complete all XSS fixes
 - ☐ Review all RLS policies
 - ☐ Implement DOMPurify globally
-

💰 Cost to Production Ready

Minimum (Soft Launch):

- Security fixes: 96 hours
- Stripe verification: 8 hours
- **Total: 104 hours** (~2.5 weeks)

Full Production:

- All above: 104 hours
 - Testing suite: 168 hours
 - iOS launch: 40 hours
 - Performance: 112 hours
 - **Total: 424 hours** (~10-14 weeks)
-

☑ What's Already Working

Production Ready NOW:

- ☒ Customer ordering system (web)
- ☒ Driver mobile app (Android)
- ☒ Restaurant management portal
- ☒ Admin operations portal
- ☒ Executive portals (all 4)
- ☒ Corporate governance
- ☒ Real-time order tracking
- ☒ Background checks (Checkr)
- ☒ Push notifications
- ☒ Maps & routing (Mapbox)
- ☒ Authentication system
- ☒ Database schema (502 migrations)

Stripe Integration:

- ☒ All edge functions properly configured
 - ☒ Using environment variables (no hardcoded keys)
 - ☒ Webhook handlers ready
 - ☒ Connect accounts ready
 - ⚠ Just needs verification that keys are live
-

🔍 Quick Health Check

Run these checks to assess current state:

```
# Check for wildcard CORS
grep -r "Access-Control-Allow-Origin.*\*" supabase/functions/ | wc -l
# Should be: 0

# Check for innerHTML usage
grep -r "innerHTML\|dangerouslySetInnerHTML" src/ | wc -l
# Should be: 0 (or sanitized)

# Check test coverage
npm run test:coverage
# Target: >80%

# Check bundle size
npm run build && ls -lh dist/assets/*.js
# Target: <2MB per file
```

Bottom Line: You're **82% ready**. Fix security (96 hours) + verify Stripe (8 hours) = **soft launch ready in 2-3 weeks**.